2026 스마트 의료 안전 컨퍼런스

컨설팅사의 대응 전략 분석

SaMD 사이버보안 수요에 컨설팅 시장은 어떻게 반응하고 있는가

강의 중반부 — 시장 분석

01 들어가며

왜 컨설팅사의 대응을 들여다보는가

> 초반부 결론: 도입·운영 어느 단계에서도 단독 해결이 어렵고,
> 하이브리드 조합이 불가피하다.

- 컨설팅사들의 서비스 모델·조직·도구·수익구조 **재편 양상** 분석
- 단순한 시장 관찰이 아닌, **"어떤 컨설팅사를 골라야 하는가"**의 판단 기준 마련

컨설팅사들이 합의하는 5가지

각기 다른 프레임이지만, 바닥에 깔린 흐름은 놀랍도록 일치합니다

1. **포지셔닝 전환** — 문서 대행사에서 전주기 파트너로
2. **수익모델 재편** — 일회성 프로젝트에서 리커링 구조로
3. **서비스 통합** — RA/QA + 제품보안 + DevSecOps
4. **AI = 증폭 수단** — 대체가 아니라 가속
5. **글로벌 규제 정합성** — 차별화 요소로 부상

포지셔닝 전환 + 수익모델 재편

보안 문서 작성 지원업체 → SaMD 규제형 사이버보안 관리체계 구축·운영 파트너

공통적으로 제시되는 **3층 수익 구조**

프로젝트형	초기 도입, 일회성	Gap 분석, 관리체계 수립, 파일럿 적용
리테이너형	월정·연간 계약	vCISO, 취약점 모니터링, 정기점검, 변경영향평가
플랫폼형	구독·도구 기반	AI 문서 생성기, CVE-SBOM 매칭, SaaS 대시보드

서비스 통합 + AI 증폭

교차점의 공백을 메우는 5개 역할

- **규제/품질** — 디지털의료제품법, GMP/QMS
- **제품보안** — 위협모델, SDL, 취약점 대응
- **SW/클라우드** — SaaS형 SaMD, CI/CD
- **운영서비스** — 리테이너, 사고대응
- **AI/자동화** — 도구화, 정합성 검증

AI 전략의 3가지 수렴점

- **원가 절감** — 1인 컨설턴트 서비스 범위 확장
- **품질 일관성** — 개인 역량 편차를 AI 검증이 보완
- **고객 자립 지원** — 도구 이전으로 관계 장기화

> 전문가가 프레임을 설계하고, AI가 초안·정리·추적성·반복업무를 가속한다.

글로벌 규제 정합성이 차별화 요소

격차 발생

국내 식약처 보안지침**만** 다루는 컨설팅사

vs

FDA · EU MDR · IMDRF N60 · IEC 81001-5-1을
통합 프레임워크로 제시하는 컨설팅사

선택 기준

Crosswalk 매핑 역량

해외 진출 수요가 있는 고객에게 **글로벌 규제 매핑 역량**이 컨설팅사 선택의 핵심 기준이 됩니다.

06 대응 유형

대응 전략 4가지 유형 — A & B

유형 A

전주기 하이브리드형

프로젝트 + 리테이너 + 플랫폼 3층 구조.
Basic → Standard → Premium 성숙도별 패키지.

- **강점:** 고객 락인, 안정적 재무
- **약점:** 초기 조직 구축 비용

적합: 중견 이상 컨설팅사

유형 B

CaaS 중심형

구독형 보안 관리 서비스. 중소 SaMD 제조사 대상.
MSSP 전략적 제휴로 24/7 운영 역량 확보.

- **강점:** 진입장벽 해소, 반복 매출
- **약점:** MSSP 의존, 커스터마이징 제한

적합: MSSP 파트너십 보유 조직

대응 전략 4가지 유형 — C & D

유형 C

AI-Native 플랫폼형

AI를 서비스 전달 방식 자체로 전환.
컨설팅 → Retainer → SaaS 구독 진화.

- **강점:** 원가 경쟁력, 확장성
- **약점:** 플랫폼 개발 투자 필요

적합: 소규모·1인, AI 역량 보유

유형 D

기술 심층 특화형

SBOM 관리, 침투 테스트, 위협 인텔리전스, VDP 대행.
글로벌 보안 벤더 파트너십 기반.

- **강점:** 기술적 차별화
- **약점:** 규제 문서화 공백

적합: 보안 기술 중심 기업

서비스 포트폴리오 — 도입 단계

상품 (통칭)	기간	성격	가격대
Quick Scan / 진단형	2~4주	현황 진단 + 로드맵	저가 진입
Full Build / 풀패키지	4~6개월	관리체계 전체 수립	**핵심 수익**
Co-Build / Advisory	6~9개월	내부 주도 + 전문가 동행	중간 가격
우수 관리체계 인증 지원	6~12개월	허가 혜택 연계 전략	**고부가**

서비스 포트폴리오 — 운영 단계

상품 (통칭)	주기	성격
Annual Retainer	월정	취약점 모니터링, 보고서, IR 지원
Annual Audit	연 1회	보안지침 준수 독립 검증
침해행위 긴급 대응	사고 발생 시	신고 지원, RCA, 재발 방지
vCISO 지원	월간	외부 보안책임자 역할
변경영향평가 지원	상시	통신기능 변경 ↔ 보호조치 ↔ 변경관리

AI/도구 기반 상품

모듈	기능
CVE-SBOM 자동 매칭 봇	SBOM 업로드 → 신규 CVE 자동 알림
사이버보안 문서 자동 생성기	제품 정보 → 절차서·IRP 초안
식약처 신고 보조 챗봇	증상 입력 → 신고 양식 + 조치 가이드
보안 감사 체크리스트 자동화	증적 업로드 → 준수 대시보드
규제 모니터링 봇	식약처·FDA 공고 → 고객 영향 분석

"허가 시점 문서 작성" 단일 상품 → 도입-운영-도구화로 이어지는 다층 포트폴리오

4 함정

컨설팅사들이 경고하는 4가지 함정

= 제조업체가 컨설팅사 선택 시 체크해야 할 리스크 지표

- **문서 대행 중심 접근** — 심사 시점엔 그럴듯하지만, 운영 증적이 없으면 곧 무너짐
- **일반 정보보안 프레임 단순 이식** — ISMS를 그대로 가져오면 환자안전·임상성·인허가 구조 미반영
- **개발조직과 분리된 규제문서 작성** — 실제 아키텍처·API·배포방식을 모르면 완성도 높은 체계 불가
- **AI 무통제 사용** — 빠른 생산 가능하나, 오반영·정보유출·부정확 기술서술이 리스크 증폭

역으로 말하면: "이 네 가지 함정을 피하고 있는가"가 컨설팅사 선택의 핵심 체크포인트

컨설팅 시장이 가리키는 3가지 신호

1. **"제대로 된" 컨설팅사의 모습이 바뀌고 있다**
   과거: 템플릿·심사 통과 경험 → 현재: 규제 해석 + 아키텍처 이해 + 운영 연속성 + AI 통제

2. **리테이너가 핵심이라는 것은, 제조업체도 그렇게 계약해야 한다는 뜻**
   "한 번에 끝나는 구축 프로젝트"만 찾는다면, 규제 구조와 어긋난 계약

3. **AI는 선택이 아니라 전제 조건**
   AI 미활용 → 원가 경쟁력 하락, 품질 편차 확대, 고객 자립 도구 부재

그렇다면 제조업체는 무엇을 해야 하는가

초반부 확인

단독 옵션은 없고,
하이브리드가 답이다

중반부 확인

전주기 파트너·리커링·AI-Native로
시장이 재편되고 있다

공급 측 분석만으로는 **내일 아침 무엇을 해야 할지** 알 수 없습니다.

후반부에서는: 기업 규모·보안 성숙도·시급성별 의사결정 가이드, 컨설팅사 선택 체크리스트, 단계별 실행 로드맵